

JR Clark (002035589)
NEU DAMG7350 (Spring 2026)

ASSIGNMENT: Module 4 – Report: Secure Storage and Retention Practices at Abbott: A Practical Review of Consumer Data Governance

Introduction

Chicago-based Abbott Laboratories operates in a highly regulated global environment where even basic marketing data can trigger privacy, regulatory, and accessibility obligations. This paper focuses specifically on the lifecycle, storage, retention, and governance of consumer PII collected through Abbott's public-facing marketing websites. My experience is centered on these web properties and the associated marketing technology ecosystem. The data flows and governance processes described here may differ from the workflows used for health data generated by Abbott's medical devices and mobile applications, such as the FreeStyle Libre continuous glucose monitoring system, which follow additional regulatory and technical requirements. Within the scope of the public-facing websites, Abbott must balance marketing needs with strict legal, privacy, and accessibility standards (World Wide Web Consortium, 2018). The result is a mature, cloud-first governance model that emphasizes data minimization, purpose limitation, and operational discipline. Abbott's approach has even held up in litigation (Hernandez v. Abbott Laboratories, 2025).

Sensitive Data Type and Data Lifecycle Mapping

Sensitive Data Type: The data examined here is consumer PII collected through Abbott brand websites. Typical fields include name, email address, country, product interest, and consent preferences. These fields fall under global privacy laws such as GDPR and CCPA (European Union, 2016; California Legislature, 2018).

Collection: No form or webpage at Abbott goes live without passing through MLR (Marketing–Legal–Regulatory) and Privacy review. Abbott also embeds WCAG 2.1 AA accessibility requirements into form design to avoid accessibility complaints or lawsuits (World Wide Web Consortium, 2018). Consent is managed through OneTrust, which governs cookie banners, opt-in language, and downstream preference handling. A notable governance case involved a marketing attempt to add a secondary profiling form on a thank-you page after users requested a free product sample. Users overwhelmingly declined to provide the extra information, and the project stalled under legal and privacy review. It was eventually sunsetted, reinforcing Abbott’s data-minimization culture.

Transfer: Once submitted, form data flows into Salesforce, Abbott’s system of record for consumer marketing data. Some third-party processors temporarily handle submissions, but they must demonstrate compliance with applicable privacy laws such as GDPR, CCPA, and Nevada’s privacy statutes (European Union, 2016; California Legislature, 2018; Nevada Legislature, 2019).

Storage: Abbott is a cloud-first organization. All marketing, CRM, and consent data is stored in SaaS platforms such as Salesforce, Adobe Experience Manager, and OneTrust. This aligns with modern expectations for secure cloud storage and vendor-managed redundancy (Abbott Laboratories, 2024).

Use: Marketing teams access data only through approved workflows. All access is logged, and segmentation prevents unauthorized use, supporting confidentiality and integrity principles consistent with global privacy regulations (European Union, 2016).

Retention: Abbott follows a global retention schedule that governs how long consumer data may be stored. Consent expiration is managed through OneTrust. Internally, Abbott enforces

strict email retention policies—30 days in the inbox and up to 18 months in user-created archive folders—to prevent employees from using email as a long-term storage system and to reduce risk of running afoul of regulatory requirements.

Destruction: Data is deleted or anonymized based on retention rules. When a user withdraws consent, OneTrust triggers suppression across all connected systems. Vendors are contractually required to delete temporary data and may be asked to provide deletion confirmation, consistent with GDPR’s right to erasure (European Union, 2016).

Storage Technology Evaluation: Abbott’s storage model is entirely SaaS-based, which shifts physical infrastructure responsibilities to vendors while allowing Abbott to focus on governance, configuration, and access control.

Cloud Architecture and Security Controls: SaaS platforms provide multi-zone redundancy, daily backups, encryption, and disaster recovery SLAs. These controls support confidentiality, integrity, and availability requirements under global privacy laws (European Union, 2016; California Legislature, 2018).

CIA Triad in a SaaS Context

- **Confidentiality:** encryption, segmentation, RBAC, and consent governance.
- **Integrity:** audit logs, controlled integrations, and vendor SLAs.
- **Availability:** vendor-managed redundancy and daily backups.

Limitations

SaaS reliance introduces some constraints. Abbott has limited visibility into how vendors sunset temporary databases, and retention timelines may vary across processors. Temporary storage during form submission also introduces risk.

Compliance and Governance Assessment

Applicable Regulations: Abbott's global presence subjects it to GDPR (European Union, 2016), CCPA/CPRA (California Legislature, 2018; California Privacy Protection Agency, 2020), the Washington My Health My Data Act (Washington State Legislature, 2023), Nevada privacy laws (Nevada Legislature, 2019), CAN-SPAM (Federal Trade Commission, 2003), WCAG 2.1 AA (World Wide Web Consortium, 2018), and HIPAA for certain product lines.

Governance Strengths: Abbott's governance model is mature and operationalized. OneTrust centralizes consent management and synchronizes opt-outs across systems. Vendor onboarding requires security documentation and alignment with Abbott's retention and deletion requirements. Accessibility compliance is embedded into form design (World Wide Web Consortium, 2018). Abbott's governance approach has also been validated in litigation (Hernandez v. Abbott Laboratories, 2025).

Governance Tensions and Gaps: Marketing's desire for richer profiling data often conflicts with legal and privacy requirements. Accessibility requirements can limit design flexibility. Vendor retention timelines are not always transparent, and employees sometimes rely on email retention loopholes.

Improvement Recommendations

1. Implement Automated Data Lineage Tracking for Vendor Access
 - a. This would strengthen GDPR Article 30 compliance (European Union, 2016).
2. Require Vendor Deletion Certificates for Temporary Data
 - a. Formal deletion confirmation would reduce long-term exposure and ensure alignment with Abbott's global retention schedule.
3. Expand Purpose-Based Segmentation Into Access Zones

- a. This would reinforce purpose limitation requirements under GDPR and CCPA (European Union, 2016; California Legislature, 2018).
4. Strengthen Internal Documentation Practices
- a. Reinforcing the use of Jira, Confluence, and SharePoint as systems of record would reduce reliance on email and improve auditability.

Conclusion

Abbott's approach to secure storage and retention reflects a strong privacy-by-design culture supported by formal review processes, SaaS-based security controls, and centralized consent management. While opportunities exist to enhance vendor oversight and internal documentation practices, Abbott's governance model provides a solid foundation for managing consumer PII in a complex regulatory environment. The fact that Abbott's practices have held up in court further demonstrates the effectiveness of its data governance framework (Hernandez v. Abbott Laboratories, 2025).

METHODOLOGY

This paper was developed using a combination of my professional experience at Abbott and academic analysis aligned with the course requirements. I drafted all substantive content, including descriptions of Abbott's data lifecycle, SaaS architecture, vendor segmentation practices, email retention policies, accessibility considerations, and the governance case study involving the thank-you-page profiling attempt. I also identified and incorporated the relevant litigation example based on publicly available information.

Microsoft Copilot was used as a writing support tool to help shape the structure of the paper, refine transitions between sections, adjust tone for academic clarity and flow, and evaluate the draft against the assignment rubric to ensure full coverage of each criterion. Copilot did not generate any Abbott-specific examples, operational details, or proprietary information. All organizational insights and real-world examples originate from my own knowledge and experience.

REFERENCES

Abbott Laboratories. (2024). Abbott privacy policy. <https://www.abbott.com/en-us/privacy-policy>

California Legislature. (2018). California Consumer Privacy Act (CCPA). https://leginfo.legislature.ca.gov/faces/codes_displayText.xhtml?division=3.&chapter=55.&part=4.&lawCode=CIV

California Privacy Protection Agency. (2020). California Privacy Rights Act (CPRA). <https://cppa.ca.gov/regulations/cpra.html>

European Union. (2016). General Data Protection Regulation (GDPR). <https://eur-lex.europa.eu/eli/reg/2016/679/oj>

Federal Trade Commission. (2003). Controlling the Assault of Non-Solicited Pornography and Marketing (CAN-SPAM) Act of 2003. <https://www.ftc.gov/business-guidance/resources/can-spam-act-compliance-guide-business>

Hernandez v. Abbott Laboratories, No. 1:24-cv-08289 (N.D. Ill. Jan. 2025). <https://law.justia.com/cases/federal/district-courts/illinois/ilndce/1:2024cv08289/464231/32/>

Nevada Legislature. (2019). Nevada Privacy Law (NRS 603A). <https://www.leg.state.nv.us/NRS/NRS-603A.html>

Washington State Legislature. (2023). My Health My Data Act. <https://app.leg.wa.gov/RCW/default.aspx?cite=19.373>

World Wide Web Consortium. (2018). Web Content Accessibility Guidelines (WCAG) 2.1. <https://www.w3.org/TR/WCAG21/>